

Clase 161 — Red Team vs pentest: filosofía y objetivos

Parte: **7 — Red Team y operaciones ofensivas** · Fuente: *Red Team Development and Operations (Vest & Tubberville)* 🕒 Duración estimada: **90 min** · Nivel: **Intermedio**

🎯 Objetivo

Entender qué distingue realmente a un ejercicio de Red Team de un pentest tradicional: no es "hacking más avanzado", sino un cambio de filosofía. El alumno aprenderá a encuadrar una operación adversarial en torno a **objetivos de negocio**, a definir Rules of Engagement (RoE) sólidas y a articular por qué emular a un adversario mejora la defensa mucho más que un listado de vulnerabilidades.

📖 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Contrastar** pentest, Red Team y vulnerability assessment según objetivo, alcance y métrica de éxito.
- 2. **Redactar** los objetivos de una operación (flags/crown jewels) y sus RoE mínimas.
- 3. **Explicar** el concepto de "assumed breach" y cuándo conviene sobre un ataque desde cero.
- 4. **Situar** al Red Team dentro del modelo de madurez defensiva de una organización.
- 5. **Diseñar** los criterios de detección/respuesta que el ejercicio pretende evaluar.

📚 Temas

#	Tema	Por qué importa
1	Pentest vs Red Team vs VA	Evita vender un servicio por otro y fija expectativas
2	Objetivos ("crown jewels")	Un Red Team persigue metas, no cobertura exhaustiva
3	Rules of Engagement	Define lo permitido; protege legal y operativamente
4	Assumed breach	Ahorra tiempo cuando el foco es detección, no perímetro
5	Threat-informed vs opportunistic	Emular a un actor real da realismo y relevancia
6	Trusted agent y white cell	Coordina el ejercicio y evita incidentes reales
7	Métricas de éxito	Traduce el ejercicio en valor defensivo medible

📖 Definiciones y características

- **Red Team:** emulación de un adversario con objetivos concretos, priorizando sigilo y evaluación de la capacidad de **detección y respuesta**. Característica clave: mide a la defensa, no solo al sistema.
- **Penetration test:** evaluación técnica orientada a **encontrar y demostrar** el mayor número de vulnerabilidades explotables en un alcance. Característica: cobertura amplia, ruido aceptable.

- **Rules of Engagement (RoE):** documento que fija qué, cómo, cuándo y dónde se puede atacar, contactos de emergencia y límites. Característica: es el contrato operativo.
- **Assumed breach:** se parte de un punto de apoyo ya concedido (una workstation, un usuario) para centrarse en post-explotación. Característica: optimiza el tiempo hacia el objetivo.
- **Crown jewels / flags:** los activos o acciones que definen el éxito (ej. leer la base de datos de RRHH). Característica: convierten "hackear" en un objetivo verificable.
- **White cell / trusted agent:** personas informadas que supervisan el ejercicio y pueden pausarlo. Característica: red de seguridad del engagement.

Herramientas y preparación

Esta clase es de planificación; el "tooling" es documental. Prepara:

- Una plantilla de **RoE** y de **plan de operación** (puedes basarte en las de redteam.guide).
- Un **cuaderno de operación** (Obsidian, un repo Git privado o incluso Markdown) para registrar decisiones y tiempos.
- Acceso al catálogo de **MITRE ATT&CK** para más adelante mapear las técnicas al plan.
- Un diagrama de la organización objetivo ficticia (usaremos "ACME Corp" como caso de estudio de laboratorio).

⚠️ Todo el ejercicio se plantea sobre una organización ficticia de laboratorio o con autorización escrita. La planificación sin autorización no ataca nada, pero define el marco legal que hace ético todo lo que viene después.

Laboratorio guiado (ejercicio aplicado)

Como esta clase es conceptual, el laboratorio es un **taller de planificación** de un ejercicio para "ACME Corp":

1. **Define el objetivo de negocio.** Escribe una frase única: "Demostrar si un atacante externo puede acceder a la base de datos de nómina en 3 semanas sin ser detectado."
2. **Traduce a flags técnicas.** Deriva metas verificables: (a) acceso a un endpoint de finanzas, (b) credenciales de un DBA, (c) lectura de una tabla marcada como señuelo.
3. **Elige el punto de partida.** Decide entre *external* (desde internet) o *assumed breach* (workstation ya comprometida) y justifica la elección según lo que la organización quiere evaluar.
4. **Redacta las RoE mínimas.** Ventana horaria, sistemas fuera de alcance (producción crítica, dispositivos médicos), técnicas prohibidas (DoS, ransomware real), y contactos de escalado.
5. **Define señales de detección esperadas.** Lista qué eventos debería generar cada fase y quién en el Blue Team debería verlos.
6. **Establece las métricas.** Tiempo-a-detección (TTD), tiempo-a-respuesta (TTR), y porcentaje de técnicas detectadas.
7. **Documenta un plan de comunicación** con la white cell (deconfliction): cómo confirmar que una alerta real es del ejercicio.

Ejercicios

1. Escribe en una tabla las 5 diferencias más importantes entre pentest y Red Team.

2. Redacta un objetivo de negocio y tres flags técnicas derivadas para una empresa de e-commerce.
3. Enumera 8 cláusulas que consideres imprescindibles en unas RoE y justifica dos de ellas.
4. Argumenta cuándo un *assumed breach* es mejor que un ataque desde cero, con un ejemplo.
5. Diseña una tabla de métricas (TTD/TTR/cobertura) con valores objetivo razonables.
6. Explica qué es la "deconfliction" y describe un procedimiento para evitar un incidente real innecesario.

Reto verificable

Produce un **documento de una página** ("Operation Charter") para ACME Corp que contenga: objetivo de negocio, 3 flags, tipo de inicio, 6 RoE, un plan de deconfliction y 3 métricas de éxito. **Criterio de aceptación:** cualquier persona ajena podría leerlo y saber qué está autorizado, qué se persigue y cómo se medirá el éxito, sin ambigüedad.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
El cliente esperaba "todas las vulnerabilidades"	Se vendió Red Team pero se necesitaba un pentest; alinea expectativas antes de firmar
El equipo dispara alarmas y cunde el pánico	Falta deconfliction; establece un canal y un código con la white cell
El ejercicio se sale de alcance	RoE vagas; especifica sistemas, técnicas y ventanas con precisión
No hay forma de decir si "salió bien"	Objetivos no verificables; define flags concretas y medibles
Se toca producción crítica	Falta lista de exclusiones; marca sistemas prohibidos explícitamente

Preguntas frecuentes

? ¿Un Red Team siempre es "mejor" que un pentest? No. Si una organización aún no parchea lo básico, un pentest da más valor. El Red Team evalúa detección/respuesta; solo tiene sentido cuando ya existe una capacidad defensiva que medir.

? ¿Qué es "purple team" en este contexto? Cuando Red y Blue colaboran en tiempo real para mejorar detecciones. Lo veremos en la Clase 178; aquí basta saber que es el destino natural del valor del ejercicio.

? ¿El assumed breach no "hace trampa"? No: reconoce que el phishing eventualmente funciona y enfoca el presupuesto en lo que de verdad se quiere evaluar (¿detectamos y respondemos una vez dentro?).

Referencias

- Vest, J. & Tubberville, J. *Red Team Development and Operations*. <https://redteam.guide/>
- MITRE — *Red Team measures of effectiveness*. <https://attack.mitre.org/resources/>
- NIST SP 800-115 — *Technical Guide to Information Security Testing*.
- CREST — *Red Team Guide*. <https://www.crest-approved.org/>

Siguiente clase

Clase 162 - MITRE ATT&CK como lenguaje ofensivo